# A Comprehensive Research Report

DoS/DDoS · Man-in-the-Middle · Spoofing Attacks


| | |
|---|---|
| **Author** | Farah Hassen |
| **Date** | April 2026 |

# Table of Contents


**1. Executive Summary** 3

**2. Introduction** 3

**3. Denial of Service (DoS) and DDoS Attacks** 4

3.1 How DoS/DDoS Attacks Work 4

3.2 Impact & Real-World Examples 5

3.3 Mitigation Strategies 5

**4. Man-in-the-Middle (MITM) Attacks** 6

4.1 Interception & Decryption Techniques 6

4.2 Impact & Real-World Examples 7

4.3 Mitigation Strategies 7

**5. Spoofing Attacks** 8

5.1 Types of Spoofing Attacks 8

5.2 Impact & Real-World Examples 9

5.3 Mitigation Strategies 9

**6. Comparative Analysis** 10

**7. Preventive Framework & Best Practices** 10

**8. Conclusion** 11

12

## 1. Executive Summary

Network security threats continue to evolve in sophistication, scale, and impact. This report provides a comprehensive examination of three of the most prevalent categories of network attacks: **Denial of Service (DoS/DDoS)**, **Man-in-the-Middle (MITM)**, and **Spoofing**. For each threat, we analyze the underlying mechanics, documented real-world incidents, and actionable mitigation strategies.

**KEY FINDINGS**

- DDoS attacks have grown to terabit-scale — the largest recorded attack exceeded **3.47 Tbps** (Microsoft Azure, 2021).
- MITM attacks remain persistent on unsecured networks lacking proper certificate validation.
- BEC spoofing campaigns caused over **$2.7 billion** in losses in 2022 alone (FBI IC3).
- A **defense-in-depth** posture is the most effective mitigation approach.

## 2. Introduction

Modern organizations depend on network infrastructure for virtually every operational function. As network reliance grows, so does the attack surface available to adversaries. According to IBM's *Cost of a Data Breach Report (2023)*, the average breach cost reached **$4.45 million USD**, with network-layer attacks playing a significant role.

This report targets security professionals, network administrators, students, and decision-makers who need a clear, structured understanding of attack categories and their countermeasures. All three threats examined exploit fundamental protocol weaknesses designed decades ago with trust — rather than security — as the primary design principle.

THREAT 01 — AVAILABILITY ATTACK

# 3. Denial of Service (DoS) and DDoS Attacks

A **Denial of Service (DoS)** attack attempts to make a machine, network, or service unavailable to its intended users by overwhelming it with illegitimate traffic. When launched from multiple distributed sources simultaneously, it becomes a **Distributed Denial of Service (DDoS)** attack. The goal is **disruption of availability** — one of the three pillars of the CIA triad.

## 3.1 How DoS/DDoS Attacks Work

### Volume-Based Attacks

- **UDP Flood:** Sends large numbers of UDP packets to random ports, exhausting host resources.
- **ICMP Flood (Ping Flood):** Overwhelms the target with ICMP Echo Requests faster than it can process them.
- **DNS Amplification:** Spoofed DNS queries cause large server responses directed at the victim, amplifying traffic up to 51,000x.

### Protocol Attacks

- **SYN Flood:** Exploits TCP's three-way handshake — half-open connections fill the server queue, blocking legitimate users.
- **Smurf Attack:** Broadcasts ICMP packets with the victim's spoofed IP; all network hosts reply to the victim.

### Application Layer Attacks (Layer 7)

- **HTTP Flood:** Mimics legitimate GET/POST requests to exhaust web server resources.
- **Slowloris:** Opens many partial HTTP connections, preventing the server from servicing real users.

| | |
|---|---|
| **Botnets** | Most large-scale DDoS attacks use botnets — networks of compromised IoT devices, routers, and servers. The Mirai botnet (2016) compromised 600,000+ devices to launch record-breaking attacks against major internet infrastructure. |

## 3.2 Impact & Real-World Examples

| Incident | Year | Scale | Impact |
|---|---|---|---|
| GitHub (Memcached Amplification) | 2018 | 1.35 Tbps | Mitigated in 10 min; largest attack of its time |
| Dyn DNS / Mirai Botnet | 2016 | ~1.2 Tbps | Twitter, Netflix, Reddit offline for hours |

| Incident | Year | Scale | Impact |
|---|---|---|---|
| Microsoft Azure | 2021 | 3.47 Tbps | Largest DDoS ever recorded; 10,000 sources |

## 3.3 Mitigation Strategies

- **Rate limiting** — Restrict requests per time window at the network edge.
- **Traffic scrubbing** — Route traffic through filtering centers to remove malicious packets.
- **SYN cookies** — Prevent resource allocation until TCP handshake completes, defeating SYN floods.
- **Anycast diffusion** — Spread attack traffic across a global server network.
- **Web Application Firewall (WAF)** — Detect and block Layer 7 attack signatures.
- **DDoS Protection Services** — Cloudflare, Akamai, AWS Shield provide absorbing capacity.
- **Incident Response Plan** — Document DDoS procedures and practice them via tabletop exercises.

THREAT 02 — INTERCEPTION ATTACK

# 4. Man-in-the-Middle (MITM) Attacks

A **Man-in-the-Middle (MITM)** attack occurs when an attacker secretly intercepts and potentially alters communications between two parties who believe they are communicating directly. Unlike DoS attacks, MITM threats target **all three CIA pillars**: confidentiality (reads private data), integrity (modifies data), and availability (selectively blocks traffic).

## 4.1 Interception & Decryption Techniques

### ARP Spoofing (ARP Poisoning)

ARP maps IP addresses to MAC addresses on a LAN but has no authentication. An attacker broadcasts forged ARP replies, associating their MAC with the default gateway's IP, causing all subnet traffic to flow through their machine.

### Other Interception Vectors

- **DNS Spoofing:** Corrupt DNS cache entries redirect users to malicious servers when querying legitimate domains.
- **SSL Stripping:** Downgrades HTTPS to HTTP, exposing data in plaintext while the attacker maintains HTTPS with the real server.
- **Rogue Wi-Fi Access Points:** A fake hotspot (e.g., 'Airport_Free_WiFi') routes all victim traffic through the attacker.
- **BGP Hijacking:** Manipulates internet routing tables to redirect large traffic volumes — typically a nation-state capability.

### Decryption Techniques

- **SSL/TLS Interception:** Fraudulent certificates allow the attacker to terminate and re-encrypt TLS sessions.
- **BEAST / POODLE / CRIME:** Cryptographic weaknesses in legacy TLS versions enabling partial decryption.
- **Certificate Forgery:** Presenting a falsely CA-signed certificate to the victim's browser.

## 4.2 Impact & Real-World Examples

| Incident | Year | Method | Outcome |
|---|---|---|---|
| Lenovo Superfish | 2015 | SSL interception via rogue root CA | All HTTPS traffic exposed on affected laptops |
| DigiNotar CA Breach | 2011 | Fraudulent certificate issuance | Mass surveillance of Iranian internet users |

| Incident | Year | Method | Outcome |
|---|---|---|---|
| NSA QUANTUM Program | 2013 | BGP hijacking + HTTP injection | Nation-scale traffic interception & malware delivery |

## 4.3 Mitigation Strategies

- **Enforce HTTPS / TLS 1.3** — Disable legacy TLS 1.0/1.1 across all services.
- **HSTS (HTTP Strict Transport Security)** — Prevent SSL stripping by forcing HTTPS permanently.
- **Dynamic ARP Inspection (DAI)** — Validate ARP packets on managed switches to block poisoning.
- **DNSSEC** — Cryptographically sign DNS records, preventing DNS spoofing.
- **Certificate Pinning** — Applications reject unexpected certificates, foiling forgery.
- **Mutual TLS (mTLS)** — Both client and server authenticate, defeating impersonation.
- **VPN on untrusted networks** — Encrypt all traffic on public Wi-Fi.

THREAT 03 — IDENTITY DECEPTION

# 5. Spoofing Attacks

**Spoofing** is the act of disguising a communication from an unknown or malicious source as being from a known, trusted source. While MITM attacks intercept active communications, spoofing primarily achieves **identity deception** to gain trust, redirect traffic, or bypass controls. It underpins a wide range of secondary attacks.

## 5.1 Types of Spoofing Attacks

| Type | Mechanism | Primary Use |
|---|---|---|
| IP Spoofing | Forged source IP in packet headers | Bypass firewalls; DDoS amplification |
| ARP Spoofing | Forged ARP reply on LAN | Traffic redirection; credential theft |
| DNS Spoofing | Corrupted DNS cache entries | Phishing; malware distribution |
| Email Spoofing | Forged SMTP 'From' header | Phishing; BEC fraud |
| MAC Spoofing | Changed network interface MAC address | Bypass MAC-based access controls |
| GPS Spoofing | False GPS signal broadcast | Navigation disruption; military deception |
| Caller ID Spoofing | Manipulated Caller ID display | Vishing; impersonating banks/agencies |

## 5.2 Impact & Real-World Examples

| Incident | Year | Attack Type | Loss / Impact |
|---|---|---|---|
| FACC AG (CEO Fraud) | 2016 | Email / BEC Spoofing | ~€50 million fraudulent wire transfer |
| MyEtherWallet | 2018 | BGP + DNS Spoofing | ~$150,000 in Ethereum stolen |
| Black Sea GPS Incident | 2017 | GPS Signal Spoofing | 20+ vessels displaced to inland airport |
| Twitter Bitcoin Scam | 2020 | Account takeover + impersonation | $100,000+ in minutes from verified accounts |

## 5.3 Mitigation Strategies

### Email Spoofing (SPF / DKIM / DMARC)

- **SPF (Sender Policy Framework):** DNS record specifying authorized mail servers for a domain.
- **DKIM (DomainKeys Identified Mail):** Cryptographic signatures on outgoing emails prove authenticity.
- **DMARC:** Policy built on SPF + DKIM; instructs receivers to reject/quarantine unauthenticated messages.
- Verify wire transfers via a secondary channel (phone call) regardless of email appearance.

### Network & System Spoofing

- **BCP38 Ingress Filtering:** ISPs drop packets with source IPs inconsistent with their network range.
- **DNSSEC:** Cryptographic signing of DNS zones prevents cache poisoning.
- **802.1X Network Access Control (NAC):** Authenticate devices before granting network access.
- **IPsec:** Authenticated, encrypted IP communications eliminate IP spoofing risk.

## 6. Comparative Analysis

| Attribute | DoS / DDoS | MITM | Spoofing |
|---|---|---|---|
| Primary Goal | Disruption | Interception / Manipulation | Deception / Impersonation |
| CIA Pillar | Availability | Confidentiality, Integrity | All three |
| Detection Difficulty | Low – Medium | High | Medium – High |
| Origin | Remote (distributed) | Local network preferred | Local or remote |
| Skill Required | Low (DDoS-for-hire) | Medium – High | Low – Medium |
| Common Tools | LOIC, Mirai, hping3 | Ettercap, Bettercap | Scapy, SET, sendmail |

## 7. Preventive Framework & Best Practices

A robust security posture requires a **defense-in-depth** approach — multiple overlapping layers of control so that the failure of any single layer does not compromise the entire system.

### 7.1 Defense-in-Depth Model

| | |
|---|---|
| **Perimeter** | Firewalls, IPS/IDS, DDoS scrubbing services |
| **Network** | VLANs, NAC (802.1X), encrypted protocols (TLS/IPsec) |
| **Host** | Endpoint security, patch management, OS hardening |
| **Application** | WAF, secure coding, input validation, DAST/SAST |
| **Data** | Encryption at rest, DLP solutions, access controls |
| **User** | Security awareness training, MFA, Zero Trust policy |

### 7.2 Key Controls by Category

#### Technical Controls

- Deploy and maintain **IDS/IPS** with up-to-date threat signatures.

- Apply **least privilege** access across all network resources.
- Implement **Zero Trust Architecture** — assume no implicit trust.
- Perform regular **penetration testing** and vulnerability assessments.
- Maintain **SIEM** for comprehensive log correlation and anomaly detection.

### Operational Controls

- Keep all systems **patched and updated** — most exploits target known vulnerabilities.
- Apply **network micro-segmentation** to contain lateral movement.
- Test Incident Response Plans through **tabletop exercises** at least annually.

### Emerging Defenses

- **AI/ML anomaly detection** — Identify attack patterns faster than signature-based systems.
- **SOAR** (Security Orchestration, Automation & Response) — Automate common response playbooks.
- **Deception technology (honeypots)** — Decoy systems expose attacker techniques in real time.

## 8. Conclusion

Network security threats — DoS/DDoS, Man-in-the-Middle, and Spoofing — represent a persistent and evolving challenge for organizations of all sizes. These attacks exploit fundamental characteristics of network protocols designed decades ago with trust, not security, as the guiding principle.

| | |
|---|---|
| 1 | **Understanding is the foundation of defense.**<br>Each attack type has characteristic behaviors, exploited vulnerabilities, and specific countermeasures. Security teams must understand mechanics to deploy effective defenses. |
| 2 | **No single control is sufficient.**<br>Defense-in-depth — combining technical, operational, and administrative controls — is the only effective strategy against determined adversaries. |
| 3 | **Encryption is non-negotiable.**<br>Enforcing TLS 1.3, DNSSEC, SPF/DKIM/DMARC, and IPsec eliminates entire attack categories that rely on plaintext communication. |
| 4 | **The human element remains critical.**<br>Social engineering underpins many network attacks. Security awareness training and clear incident reporting procedures are as important as any technical control. |
| 5 | **Threats evolve; defenses must too.**<br>Continuous monitoring, threat intelligence sharing, and regular assessments are essential to maintaining a current and effective defense posture. |